

# Resumen Ejecutivo y Técnico

Proyecto Encipharm / Enci Ventas

Documento preparado para reunión ejecutiva con cliente. Consolida alcance funcional, estado de desarrollo, cumplimiento, arquitectura, seguridad, QA realizado, riesgos, mejoras recomendadas y preguntas de validación.

|                                                       |
|-------------------------------------------------------|
| <b>Fecha:</b> 18 de mayo de 2026                      |
| <b>Repositorio:</b> Encipharm                         |
| <b>Tipo de sistema:</b> MiniCRM comercial web         |
| <b>Estado:</b> MVP web avanzado, previo a UAT/go-live |
| <b>Backend:</b> FastAPI + Firebase Admin + Firestore  |
| <b>Frontend:</b> React + Vite + Firebase Auth         |

**Validación local actual:** backend con 54 pruebas aprobadas, build frontend exitoso y lint frontend sin errores.

Este documento es de uso interno para preparación ejecutiva. No representa acta de aceptación final del cliente.

## 1. Resumen Ejecutivo

Encipharm / Enci Ventas es un sistema web de gestión comercial y MiniCRM diseñado para centralizar la operación del equipo de ventas. Permite administrar clientes, registrar interacciones, controlar oportunidades, gestionar propuestas y visualizar indicadores mediante dashboards diferenciados por rol.

El MVP está construido con una arquitectura web primero: frontend React/Vite, backend FastAPI, autenticación con Firebase Auth y persistencia en Cloud Firestore. El backend actúa como capa obligatoria de autorización, validación, seguridad y escritura de datos.

**Estado general:** las capacidades principales del MVP están cerradas para Development. El proyecto está en etapa de preparación de UAT, validación con usuarios reales y salida controlada.

## 2. Qué Hace El Sistema

- Autentica usuarios mediante Google SSO usando Firebase Auth.
- Valida tokens Firebase en el backend antes de permitir acceso a endpoints protegidos.

- Sincroniza usuarios autenticados en Firestore.
- Controla acceso según rol: vendedor, supervisor y admin.
- Permite crear, listar, buscar, filtrar, editar y eliminar lógicamente clientes.
- Restringe a vendedores para que operen solo clientes propios.
- Permite registrar interacciones comerciales asociadas a clientes.
- Gestiona oportunidades comerciales mediante etapas de pipeline.
- Permite crear propuestas vinculadas a oportunidades y calcular montos finales en backend.
- Entrega dashboards con métricas propias para vendedores y consolidadas para supervisores/admin.
- Expone documentación técnica y consola Swagger protegida para pruebas.
- Incluye endpoint de readiness para validar condiciones mínimas antes de UAT/go-live.

### 3. Alcance Del MVP

---

#### Incluido

- Aplicación web comercial funcional.
- Backend API protegido por Firebase JWT.
- Persistencia en Firestore.
- Gestión de usuarios y roles.
- CRM de clientes.
- Interacciones comerciales.
- Pipeline de oportunidades.
- Propuestas básicas con estados y cálculo de descuento/total.
- Dashboards vendedor y supervisor/admin.
- Importación CSV de clientes a nivel backend para admin.
- Hardening de seguridad y resiliencia.
- Documentación técnica, QA y go-live.

#### Fuera De Alcance Actual

- Aplicación mobile Flutter.
- IA, RAG o inteligencia competitiva avanzada.
- Integración con SAP/ERP.
- Integración con Google Calendar.
- Reportes extendidos y BI avanzado.
- Migración histórica de datos sin fuente aprobada.
- Automatización E2E completa con credenciales Firebase reales.

### 4. Funcionalidades Implementadas

---

| Módulo           | Funcionalidades                                                                            | Estado       |
|------------------|--------------------------------------------------------------------------------------------|--------------|
| Autenticación    | Login Google, token Firebase, sincronización backend, bloqueo por usuario inactivo.        | Implementado |
| Clientes         | CRUD, búsqueda, filtros, detalle, edición, eliminación lógica, visibilidad por vendedor.   | Implementado |
| Usuarios y roles | Listado, detalle, cambio de rol, activación/desactivación, jerarquía de permisos.          | Implementado |
| Interacciones    | Registro y listado de llamadas, correos, reuniones, visitas u otros contactos comerciales. | Implementado |
| Oportunidades    | Creación, listado, filtros, cambio de etapa, detalle con historial relacionado.            | Implementado |
| Propuestas       | Creación vinculada a oportunidad, estados, cálculo server-side de descuento y total.       | Implementado |
| Dashboards       | Métricas propias de vendedor y agregados de supervisor/admin.                              | Implementado |
| Readiness        | Validación no sensible de configuración mínima para UAT/go-live.                           | Implementado |

## 5. Desarrollo Actual Y Cumplimiento

| Etapas | Objetivo                                          | Estado  | Cumplimiento estimado |
|--------|---------------------------------------------------|---------|-----------------------|
| EPIC 1 | Base técnica, autenticación y modelo de usuarios. | Cerrado | 100%                  |

| <b>Etapas</b> | <b>Objetivo</b>                                             | <b>Estado</b>            | <b>Cumplimiento estimado</b> |
|---------------|-------------------------------------------------------------|--------------------------|------------------------------|
| EPIC 2        | CRM, roles, dashboard base, importación CSV.                | Cerrado funcionalmente   | 100%                         |
| EPIC 3        | Interacciones, oportunidades, propuestas y flujo comercial. | Cerrado para Development | 100%                         |
| EPIC 4        | Hardening, QA, dashboards y navegación por rol.             | Cerrado para Development | 100%                         |
| EPIC 5        | UAT, readiness, documentación, go-live y rollback.          | En desarrollo            | 40-50%                       |

Cumplimiento técnico para Development: **90-95%**. Cumplimiento estimado para salida productiva: **75-80%**, condicionado por UAT real, ambiente final, usuarios autorizados y aprobación formal de defectos.

## 6. Desarrollo En El Tiempo

- **Sprint 01:** estructura backend, Firebase Admin, JWT, usuarios, endpoints base y Swagger.
- **Sprint 02:** CRM real con Firestore, roles, permisos, dashboard base, CSV y hardening inicial.
- **Sprint 03:** interacciones, oportunidades, propuestas, detalle comercial y dashboard supervisor.
- **Sprint 04:** seguridad, resiliencia visual, sesión expirada, 403/404, dashboards y QA documentado.
- **Sprint 05:** UAT/go-live, readiness backend, checklist funcional, smoke test y rollback.

# 7. Detalle Técnico

## Stack Tecnológico

| Capa                   | Tecnología                  | Uso                                                   |
|------------------------|-----------------------------|-------------------------------------------------------|
| Frontend               | React + Vite                | Interfaz web SPA del MVP comercial.                   |
| Autenticación frontend | Firebase Auth               | Login Google y obtención de ID Token.                 |
| Backend                | FastAPI + Python            | API, validaciones, permisos, documentación Swagger.   |
| Autenticación backend  | Firebase Admin              | Validación de tokens Firebase.                        |
| Base de datos          | Cloud Firestore             | Persistencia de usuarios, clientes y flujo comercial. |
| Dependencias backend   | uv                          | Instalación reproducible y ejecución de tests.        |
| Deploy previsto        | Cloud Run / Vercel frontend | Backend en GCP y frontend web independiente.          |

## Arquitectura Funcional

- El usuario entra al frontend y ejecuta login con Google.
- Firebase Auth entrega un ID Token al frontend.
- El frontend envía el token al backend en `Authorization: Bearer <token>`.
- FastAPI valida el token con Firebase Admin.
- El backend consulta Firestore para obtener rol, estado y permisos.
- Las operaciones de negocio se ejecutan únicamente a través de la API.
- Firestore no queda expuesto como escritura directa desde cliente.

## Endpoints Principales

| Área              | Endpoints                                                                                                                                                  |
|-------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Salud y readiness | GET /health, GET /readiness                                                                                                                                |
| Usuario actual    | GET /me                                                                                                                                                    |
| Autenticación     | POST /auth/login, POST /auth/register                                                                                                                      |
| Clientes          | GET /clientes, POST /clientes, GET /clientes/{id}, PATCH /clientes/{id}, DELETE /clientes/{id}, POST /clientes/import-csv                                  |
| Flujo comercial   | GET/POST /interacciones, GET/POST /oportunidades, PATCH /oportunidades/{id}, GET /oportunidades/{id}/detalle, GET/POST /propuestas, PATCH /propuestas/{id} |
| Dashboard         | GET /dashboard/vendedor, GET /dashboard/supervisor                                                                                                         |
| Usuarios          | GET /users, GET /users/{uid}, PATCH /users/{uid}, PATCH /users/{uid}/role, PATCH /users/{uid}/status                                                       |

### Reglas De Autorización

- **vendedor**: opera clientes, interacciones, oportunidades y propuestas propias.
- **supervisor**: accede a información consolidada y funciones de supervisión.
- **admin**: accede a gestión completa, cambios de rol/estado e importación CSV.
- La autorización definitiva vive en backend; el frontend solo mejora la experiencia de navegación.

## 8. Seguridad Y Protecciones Extra

| Riesgo            | Control implementado                                      |
|-------------------|-----------------------------------------------------------|
| Acceso sin sesión | Endpoints protegidos exigen token Bearer Firebase válido. |

| Riesgo                                 | Control implementado                                                                                |
|----------------------------------------|-----------------------------------------------------------------------------------------------------|
| Usuario desactivado sigue usando token | <code>activo=false</code> bloquea login, <code>/me</code> y endpoints protegidos.                   |
| Acceso a datos ajenos                  | Control de propiedad por <code>vendedorUid</code> y rol.                                            |
| Eliminación irreversible               | Cientes usan baja lógica con <code>deletedAt</code> .                                               |
| Uso directo de Firestore desde cliente | Reglas Firestore versionadas con denegación total.                                                  |
| Ráfagas o abuso básico                 | Rate limit de 120 solicitudes por minuto por IP.                                                    |
| Payloads sobredimensionados            | Límite global de 1 MB por request.                                                                  |
| CSV gigante o inválido                 | CSV limitado a 1 MB, 1000 filas y UTF-8.                                                            |
| Formula injection                      | Rechazo de textos iniciados con <code>=</code> , <code>+</code> , <code>-</code> o <code>@</code> . |
| CORS permisivo                         | Configuración rechaza <code>*</code> en producción.                                                 |
| Token persistente en Swagger           | Uso de <code>sessionStorage</code> y no persistencia permanente.                                    |
| Sesión expirada                        | Evento global frontend fuerza logout y retorno a login.                                             |
| Rutas incorrectas o sin permiso        | Páginas 404 y 403 controladas.                                                                      |

| Riesgo                            | Control implementado                                                                 |
|-----------------------------------|--------------------------------------------------------------------------------------|
| Click doble o errores silenciosos | Controles de guardado, disabled states y manejo de errores en pantallas comerciales. |

## 9. QA Realizado

### Validación Automatizada Actual

| Área           | Comando                        | Resultado                 |
|----------------|--------------------------------|---------------------------|
| Backend        | <code>uv run pytest</code>     | 54 pruebas aprobadas.     |
| Frontend build | <code>npm.cmd run build</code> | Build productivo exitoso. |
| Frontend lint  | <code>npm.cmd run lint</code>  | Sin errores de ESLint.    |

### Cobertura Backend

- Permisos de clientes y visibilidad por vendedor.
- Bloqueo de acceso a cliente ajeno.
- Alta, edición y baja lógica de clientes.
- Importación CSV válida e inválida.
- Duplicados en CSV y duplicados contra CRM existente.
- Usuarios activos/inactivos.
- Cambios de rol y estado.
- Flujo de interacciones, oportunidades y propuestas.
- Validación de propuesta asociada a oportunidad visible.
- Readiness para UAT/go-live.
- Hardening de seguridad: límites, CORS, headers y errores.

### QA Documentado

- QA EPIC 2 backend.
- Auditoría QA y seguridad EPIC 3.
- Hardening de seguridad y resiliencia.
- QA EPIC 4 de rutas, dashboards y navegación por rol.
- Checklist UAT EPIC 5.
- Matriz de defectos UAT por severidad.



- Runbook de go-live y rollback.

### Pendiente QA

- Prueba manual completa con usuarios Firebase reales.
- E2E automatizado con Playwright o herramienta equivalente.
- Validación visual completa en ambiente UAT.
- Smoke test post despliegue.
- Pruebas de carga o volumen antes de escalar datos reales.

## 10. Observaciones

- El sistema está en condiciones de demo ejecutiva y UAT controlado.
- La principal brecha actual es operativa, no funcional: falta validación con ambiente y usuarios reales.
- El backend concentra las reglas críticas, por lo que no depende de controles visuales del frontend para proteger datos.
- El uso de filtros en memoria sobre Firestore es aceptable para MVP, pero debe evolucionar con índices y queries server-side al crecer el volumen.
- La importación CSV está disponible en backend para admin; debe confirmarse si el cliente necesita interfaz visual para esa operación.
- La migración histórica debe mantenerse fuera de alcance hasta recibir fuente de datos, reglas de normalización y criterios de calidad.
- Mobile, SAP, IA, Calendar y reportes avanzados deben tratarse como Fase 2.

## 11. Riesgos Residuales

| Riesgo                            | Impacto                                           | Mitigación recomendada                                                   |
|-----------------------------------|---------------------------------------------------|--------------------------------------------------------------------------|
| Firestore real no validado en UAT | Bloqueo de login o permisos en ambiente cliente.  | Crear cuentas de prueba por rol y ejecutar checklist UAT.                |
| Consultas Firestore en memoria    | Riesgo de rendimiento al aumentar volumen.        | Migrar a queries con índices por vendedorUId, clienteId, estado y etapa. |
| Sin E2E automatizado              | Mayor riesgo de regresión visual o de navegación. | Implementar Playwright con login mockeado o ambiente de prueba.          |

| Riesgo                                        | Impacto                                              | Mitigación recomendada                                                     |
|-----------------------------------------------|------------------------------------------------------|----------------------------------------------------------------------------|
| Migración histórica indefinida                | Datos incompletos al iniciar operación real.         | Solicitar fuente, diccionario, reglas de limpieza y piloto de importación. |
| Reglas comerciales pendientes de confirmación | Ajustes tardíos en estados, permisos o aprobaciones. | Validar pipeline, estados, roles y aprobaciones en reunión ejecutiva.      |

## 12. Mejoras Recomendadas

- Agregar pruebas frontend con Vitest y React Testing Library.
- Agregar pruebas E2E con Playwright para flujos críticos.
- Migrar filtros Firestore a consultas optimizadas con índices.
- Agregar unicidad de email en alta manual si el negocio lo exige.
- Crear pantalla de importación CSV para admin si será usada por operación.
- Agregar exportación de clientes, oportunidades y propuestas.
- Mejorar dashboards con tendencias temporales y métricas de conversión.
- Agregar recordatorios de seguimiento comercial.
- Permitir configuración de etapas de pipeline si el cliente tiene proceso propio.
- Preparar integración futura con ERP/SAP.
- Planificar módulo mobile como Fase 2.
- Centralizar logger frontend y reducir mensajes no necesarios en producción.

## 13. Preguntas Para El Cliente

- ¿Los roles vendedor, supervisor y admin cubren la operación real?
- ¿Qué estados de cliente, oportunidad y propuesta usan hoy?
- ¿El pipeline actual refleja sus etapas reales de venta?
- ¿Qué campos son obligatorios para registrar un cliente?
- ¿El email del cliente debe ser único?
- ¿Necesitan importación CSV desde interfaz o basta con operación técnica/admin?
- ¿Qué reportes son indispensables para gerencia?
- ¿Qué métricas definen éxito comercial: monto, probabilidad, cierre, actividad o conversión?
- ¿Quién puede aprobar propuestas y bajo qué condiciones?
- ¿Qué datos históricos deben migrarse y desde qué fuente?

- ¿Qué acciones requieren auditoría formal?
- ¿Qué volumen estimado de clientes, oportunidades y propuestas esperan en 6 y 12 meses?
- ¿Qué dominios, usuarios y roles se usarán para UAT?
- ¿Cuál será el criterio formal de salida productiva?

## 14. Preguntas Para Frontend

---

- ¿Se mantendrá el diseño actual o habrá lineamientos visuales del cliente?
- ¿Se necesita UI para administración de usuarios y roles?
- ¿Se necesita pantalla de importación CSV para admin?
- ¿El pipeline debe ser Kanban con drag and drop o basta con selector de etapa?
- ¿Qué acciones deben ocultarse por rol además del bloqueo backend?
- ¿Se requieren estados de carga/error más uniformes entre pantallas?
- ¿Qué vistas deben optimizarse primero para mobile?
- ¿Qué campos deben mostrarse en tablas y cuáles solo en detalle?
- ¿Se necesita exportar clientes, oportunidades o propuestas desde frontend?
- ¿Se implementará Vitest/RTL para pruebas unitarias de interfaz?
- ¿Se implementará Playwright para E2E?
- ¿Se requiere branding Encipharm/Enci más formal para demo ejecutiva?

## 15. Mensaje Ejecutivo Sugerido

---

El sistema ya cuenta con un MVP web funcional para gestión comercial: autenticación segura, CRM de clientes, roles, pipeline de oportunidades, propuestas, interacciones y dashboards. Técnicamente, las etapas principales de desarrollo están cerradas para Development y las pruebas locales actuales pasan correctamente. El foco pendiente es validar con usuarios reales en UAT, confirmar reglas comerciales finales, priorizar mejoras de interfaz y preparar el go-live controlado con smoke test y rollback documentados.